

03 - Gateway Module

Overview

The Gateway is the unified API entry point for all PractitionerHub services. It enforces authentication, rate limiting, request routing, circuit breaking, and WAF protection across all inbound requests.

Gateway Architecture

```
[Client / Portal / External Service]
-> [TLS 1.3 Termination]
-> [WAF: OWASP Top 10 Rules]
-> [OAuth2.0 Token Validation]
-> [Rate Limiter]
-> [Router]
  - /api/efile    -> eFile Transmission
  - /api/refund   -> Refund Intelligence
  - /api/client   -> Client Masterfile
  - /api/tc       -> TC Sync
  - /api/identity -> Identity Verification
  - /api/tpb      -> TPP Reconciliation
  - /api/tunnel   -> IRS Tunnel Engine
  - /api/status   -> ERO Status Engine
-> [Circuit Breaker]
-> [Upstream Engine]
```

Route Definitions

Route Prefix	Target Engine	Auth Required	Rate Limit
/api/efile	eFile Transmission	Bearer + EFIN scope	60/min
/api/refund	Refund Intelligence	Bearer	120/min
/api/client	Client Masterfile	Bearer	200/min
/api/tc	TC Code Sync	Bearer + Admin scope	30/min
/api/identity	Identity Verification	Bearer	20/min
/api/tpb	TPP Reconciliation	Bearer + Finance scope	30/min
/api/tunnel	IRS Tunnel	Internal Only	10/min

Route Prefix	Target Engine	Auth Required	Rate Limit
/api/status	ERO Status	Bearer	60/min
/api/health	Health Aggregator	None	1000/min
/api/audit	Audit Log Reader	Bearer + Admin scope	10/min

Authentication Flow

Client -> POST /auth/token

Body: { client_id, client_secret, grant_type, scope, efin }

Response: { access_token, token_type, expires_in, scope }

All subsequent requests:

Authorization: Bearer <access_token>

X-EFIN: 748335

Token Claims (JWT)

```
{
  "iss": "https://auth.practitionerhub.internal",
  "sub": "preparer_id_abc123",
  "aud": "practitionerhub-api",
  "efin": "748335",
  "role": "senior_preparer",
  "scope": ["efile", "client:read", "client:write", "refund:read"],
  "exp": 1752278400,
  "iat": 1752274800
}
```

Rate Limiting Policy

Tier	Requests/Min	Burst	On Exceed
Standard	100	120	HTTP 429
Premium	500	600	HTTP 429
Internal Service	Unlimited	N/A	N/A
Unauthenticated	10	10	HTTP 429 + block 60s

Circuit Breaker Configuration

```
circuit_breaker:
  failure_threshold: 5
  success_threshold: 2
  timeout_seconds: 30
  engines:
```

```
efile: { enabled: true }
refund: { enabled: true }
tc_sync: { enabled: true }
tunnel: { enabled: true, timeout_seconds: 10 }
```

Health Endpoint Example

```
{
  "status": "healthy",
  "efin": "748335",
  "timestamp": "2026-07-11T19:24:00Z",
  "engines": {
    "efile": "healthy",
    "gateway": "healthy",
    "tunnel": "healthy",
    "a2a": "healthy",
    "fire": "healthy",
    "mef": "healthy",
    "identity": "healthy",
    "tpp": "healthy",
    "masterfile": "healthy",
    "tc_sync": "healthy",
    "refund_intelligence": "healthy"
  }
}
```

WAF Rules Active

Rule Set	Enabled	Description
OWASP CRS 3.3	Yes	Core rule set
SQL Injection	Yes	All endpoints
XSS	Yes	All endpoints
Path Traversal	Yes	All endpoints
Geo-block non-US	Yes	IRS compliance
Bot Signature	Yes	Automated scanners
PII in URL Params	Yes	Blocks SSN in query string